Clinical AI QA: P2 and P3 Fix Report

Result: 16 of the 19 P2 and P3 items are fixed and deployed.
P2: 5 of 8 fixed. Issues 8 and 17 are partly fixed: two-factor sign-in was built and then removed, and password reset emails cannot be delivered from production because no mail server is set up. Issue 10 is not fixed: the API is still on the sslip.io address and nothing is hosted in Saudi Arabia.
P3: all 11 fixed. The hospital list still shows only fictional demo hospitals, by design (Issue 25).

Priority	Items	Fixed	Partly fixed	Not fixed
P2	8	✅ **5**	🔴 **2 (8, 17)**	🔴 **1 (10)**
P3	11	✅ **11**	0	0
Total	**19**	✅ **16**	🔴 **2**	🔴 **1**

✅ Fixed and verified 🔴 Not fully fixed (partly fixed or open)

Part 1: P2 items

P2 status against the QA list

Issue	QA request	Status	What was done
3	Privacy and Terms with Saudi content (PDPL, DPO, Saudi law) in English and Arabic	✅ Fixed	Both pages rewritten in English and Arabic: PDPL rights, SDAIA as the authority, Saudi governing law, a DPO contact (dpo@esap.ai) and a plain statement that ESAP is **not yet hosted in Saudi Arabia**. Still marked "Draft, not yet reviewed by counsel". **Also added:** a "Saudi registrations and approvals" section in Terms and a matching FAQ answer (English and Arabic) list the planned Saudi approvals and say plainly that none is held yet.
7	Ops Incidents: breach flag, 24 h / 72 h timers, notification templates	✅ Fixed	An incident can be flagged as a breach when it is opened or later. It gets two deadlines from the time ESAP became aware: 24 h to tell the affected hospital and 72 h for the hospital to notify SDAIA. Hospital and SDAIA notification templates are filled in from the incident.
8	MFA for admins, account settings, lockout, 15–30 min idle timeout	🔴 Partly fixed	Done: lockout for 15 minutes after 5 wrong passwords (also for unknown addresses), sign-out after 30 minutes idle, and an Account page with "Change my password". Two-factor sign-in was built and enforced for admins, then **removed**. No account has two-factor today.
9	Versioned processing consent and retention purge with reports	✅ Fixed	Patients give or withdraw processing consent by purpose and version, and withdrawing stops AI use of their data. Stopping sharing now records the withdrawal time. A retention purge runs every 24 h and on demand from the admin console, and writes a report each time.
10	API on an ESAP domain (e.g. api.care.esap.ai) and a Saudi hosting plan	🔴 Not fixed	The site still calls esap-api.159-195-83-232.sslip.io. api.care.esap.ai does not answer yet. The security policy already allows it, so the switch needs DNS, a certificate and one setting. No Saudi host has been chosen.

Issue	QA request	Status	What was done
11	"Demo · synthetic data only" badge on every page, including the app and login	✅ Fixed	A badge is in the header of the public site, the sign-in and sign-up pages and every signed-in screen, including the intake form.
13	Security headers (CSP, frame, nosniff, referrer) and token in an HttpOnly cookie	✅ Fixed	The site sends CSP, X-Frame-Options DENY, nosniff, Referrer-Policy and Permissions-Policy. Access-Control-Allow-Origin is care.esap.ai, not *. The session is an HttpOnly cookie and no token is kept in localStorage.
17	Self-service password reset for solo clinicians and patients	🔴 Partly fixed	Built: "Forgot password" sends a reset link by email and the person sets a new password on /reset-password. The answer is the same for unknown addresses. **Production has no mail server set up**, so the email is not sent there yet.

P2 evidence

Issue		Evidence
3	✅	**Live:** /privacy and /terms show PDPL rights, SDAIA, Saudi governing law, dpo@esap.ai and "not yet hosted in Saudi Arabia". **Code:** `frontend/src/apps/site/legalContent.ts` (English and Arabic). **Test:** `frontend/src/i18n.test.tsx` renders /privacy and /terms in Arabic, right-to-left, with no stray English.
7	✅	**Tests (pass):** `test_qa_p2::test_breach_incident_has_24h_and_72h_deadlines_and_templates`, `test_breach_flag_can_be_set_later_and_needs_ops`, `test_release_check::test_breach_aware_time_without_zone_is_utc_and_future_is_refused`. **UI:** `frontend/src/apps/ops/OpsIncidents.tsx`.
8	🔴	**Done, tests pass:** `test_lockout_after_repeated_wrong_passwords_even_for_unknown_address`, `test_idle_session_is_signed_out`, `test_release_check::test_old_failures_do_not_add_up_to_a_lockout`. **UI:** `frontend/src/apps/auth/AccountPage.tsx` (Change my password). **Gap:** `test_two_factor_sign_in_is_removed` confirms no account has two-factor.
9	✅	**Tests (pass):** `test_processing_consent_is_versioned_and_withdrawal_stops_ai_use`, `test_sharing_revoke_stamps_withdrawal_time`, `test_retention_purge_deletes_old_assessments_and_writes_a_report`, `test_release_check::test_auditor_cannot_run_the_retention_purge`. **UI:** `ProcessingConsentCard.tsx`, `RetentionCard.tsx`.
10	🔴	**Live:** https://api.care.esap.ai gives no response. The site's API calls still go to `esap-api.159-195-83-232.sslip.io`. No Saudi host chosen.
11	✅	**Code:** `DemoBadge` in `frontend/src/components/ui/domain.tsx`, rendered by the site layout, the sign-in layout and every signed-in shell. **Live:** badge visible on /product, /login and app screens.
13	✅	**Live response headers on care.esap.ai/product:** Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy. **Live API:** Access-Control-Allow-Origin: https://care.esap.ai. **Test (pass):** `test_signin_sets_httponly_cookie_and_cookie_writes_need_client_header`. **Code:** `backend/app/session_cookie.py`, `frontend/vercel.json`.
17	🔴	**Done, tests pass:** `test_patient_gets_a_reset_link_and_can_set_a_new_password`, `test_forgot_answer_is_the_same_for_unknown_addresses`. **UI:** `ResetPasswordPage.tsx`. **Gap:** no `ESAP_SMTP_*` settings on production, so the email is not sent there.

Changes since the P1 report

Issue 1 (shared demo password) is still open. Every account was first given its own password and the demo list was switched off. /demo-role then came back for the clinical and patient roles, and the six admin and ops demo accounts were later set back to the shared password as well, so 14 accounts now use it. With two-factor removed, anyone who has the shared password can sign in as Hospital Admin or Super-Admin. No real data should be put behind these accounts.

Saudi approvals on the website

Terms now has a **Saudi registrations and approvals** section, and the FAQ has a short answer that links to it. Both are in English and Arabic. They list what ESAP plans to obtain: MISA registration, CST-licensed Saudi hosting, NCA ECC/CCC controls with a penetration test, SDAIA/PDPL registration with a named DPO, IRB (NCBE) approval for a silent pilot, SFDA medical device marketing authorisation through GHAD, and SCFHS-registered clinical leads.

The text says **none of these is held yet**, and that estimates will not inform real patient care until SFDA authorisation. NPHIES and CBAHI are left out on purpose. The Arabic needs review by a native speaker.

Part 2: P3 items

P3 status against the QA list

Issue	QA request	Status	What was done
12	SEO basics and a real 404	✅ Fixed	Real robots.txt (text/plain) and sitemap.xml (application/xml), a title per page, Open Graph, canonical and hreflang tags. Unknown URLs return 404.
14	Arabic on public pages	✅ Fixed	Public and legal pages are translated, with a language switch in the site header. Choosing Arabic sets lang="ar" and dir="rtl".
15	Intake form range checks and a working Save draft	✅ Fixed	Inline range errors as you type (for example age 0–120, SpO2 50–100, systolic BP 40–300). Save draft saves on the server, confirms, and restores per clinician, including for a patient not admitted yet.
16	Intake assistant captures all vitals and labs	✅ Fixed	Heart rate, respiratory rate, SpO2, temperature, potassium and symptoms are now captured. Anything it could not map is listed as "Not captured" before "Run assessment".
18	Smaller issues	✅ Fixed	A physician is sent away from nurse-only pages. The Design system link is gone from the public footer and shows only for admin and ops staff. "Sixteen roles" and the Evidence typo are fixed. The app uses the real clock.
21	Sharing accepts an invalid recipient	✅ Fixed	The UI and the API refuse a recipient that is not a valid email or a hospital from the list.
22	Patient export leaves out the patient's own data	✅ Fixed	The export now includes intake submissions, requests and access history. The page says it is ESAP's own JSON layout, not yet FHIR.
23	Requests go to a care team that does not exist	✅ Fixed	For a patient with no hospital, corrections and other requests go to the ESAP support queue, and the app says so.
24	Times shown in the future ("in 47 d")	✅ Fixed	Bootstrap sends the real current time, so access history and requests show correct times.
25	Smaller patient-portal issues	✅ Fixed	Arabic gaps translated. Emergency text gives 997. A patient's bootstrap holds only their own identity. Every /admin path refuses non-admins. Patient two-factor is no longer relevant (removed). Fictional demo hospitals remain, by design.
26	"Design system" footer link opens a blank page	✅ Fixed	Link removed from the public footer. A signed-out visit to /design goes to the sign-in page.

P3 evidence

Issue		Evidence
12	✅	**Live:** /robots.txt 200 text/plain; /sitemap.xml 200 application/xml; /no-such-page-qa 404; /product has og:title and canonical https://care.esap.ai/. **Code:** `frontend/src/lib/pageMeta.tsx`, `frontend/public/robots.txt`, `sitemap.xml`.
14	✅	**Test:** `frontend/src/i18n.test.tsx` renders every public page in Arabic with lang="ar", dir="rtl" and no stray English. **Code:** `frontend/src/i18n/ar-site.ts`.
15	✅	**Test (pass):** `test_qa_p2::test_new_intake_draft_saves_and_restores_per_clinician`. **Code:** range checks in `frontend/src/apps/clinician/intakeForm.ts`.
16	✅	**Tests (pass):** `test_assistant_captures_the_qa_message_in_full`, `test_assistant_lists_values_it_could_not_map`, `test_release_check::test_age_and_sex_shorthand_is_captured`.
18	✅	**Code:** role route guard in `frontend/src/App.tsx`; Design system link only for admin and ops in `AppShell.tsx`. **Live:** no "Sixteen roles" on /security, no Design system link in the public footer.
21	✅	**Test (pass):** `test_qa_p2::test_sharing_refuses_an_invalid_recipient` (email and hospital cases).
22	✅	**Test (pass):** `test_patient_export_includes_submissions_requests_and_access_history`.
23	✅	**Test (pass):** `test_solo_patient_request_goes_to_esap_support_and_says_so`. **UI:** `RequestDialog.tsx`.
24	✅	**Test (pass):** `test_bootstrap_reports_the_real_time`. **Code:** `frontend/src/lib/format.ts`.
25	✅	**Tests (pass):** `test_patient_cannot_reach_admin_interop`, `test_qa_followup::test_every_admin_path_refuses_non_admins`, `test_release_check::test_access_history_matches_the_exact_patient_only`.
26	✅	**Code:** signed-out /design goes to sign-in (`frontend/src/App.tsx`). **Live:** no Design system link in the public footer.
Extra	✅	**Test (pass):** `test_qa_p2::test_closing_a_patient_account_really_closes_it`.

Also fixed (results table)

Close my account: typing CLOSE now really closes the account. It used to only sign the person out.

Verification

Check	Result
Backend tests (after two-factor removal)	357 passed, including the P2/P3 tests in test_qa_p2, test_qa_followup and test_release_check
Frontend tests	203 passed, 9 skipped
Typecheck and production build	Clean
Backend QA tests (test_qa_p2, test_qa_followup, test_release_check)	73 passed
Terms and FAQ Saudi approvals text	Renders in English and Arabic (right-to-left), 7 items, "none held yet", Terms contents link and FAQ link work
Live site checks	Security headers present on /product; API calls still go to sslip.io; api.care.esap.ai does not respond; robots.txt text/plain, sitemap.xml application/xml, unknown URL 404, OG and canonical tags present

Deployment: the P2 and P3 fixes are live in production. Two-factor sign-in has been removed from production.

QA retest guide: P2

Issue	Retest steps and expected result
3	Open /privacy and /terms, then switch the language to Arabic. Expect PDPL rights, SDAIA, Saudi governing law, dpo@esap.ai and "not yet hosted in Saudi Arabia", and in Arabic expect lang="ar" and right-to-left text. Also check /terms#saudi-approvals and the FAQ question "Which Saudi approvals is ESAP working towards?".
7	Needs the Super-Admin account. Ops > Incidents > new incident with "breach" ticked. Expect 24 h and 72 h deadlines and the hospital and SDAIA templates. An incident opened without the flag can be flagged later.
8	Enter a wrong password 5 times: expect a lockout message for 15 minutes. Sign in, leave the tab for 30 minutes, then click: expect to be signed out. Profile menu > Account > Change my password works. No code is asked at sign-in (two-factor removed).
9	Patient > Settings: give and then withdraw processing consent and check the version and withdrawal time. Hospital Admin > Audit > Retention: run the purge and expect a report.
10	DevTools > Network on any app page. Today calls go to sslip.io (not fixed).
11	Open /product, /evidence, /login, /signup, the doctor worklist and New encounter. Expect the "Demo · synthetic data only" badge in the header of each.
13	Check the response headers of /product. After sign-in, DevTools > Application: the session cookie is HttpOnly and localStorage has no esap.token.
17	Needs a mail server on production. Until then, test on a server with ESAP_SMTP_* set: Forgot password > email arrives > set a new password > sign in.

QA retest guide: P3

Issue	Retest steps and expected result
12	Open /robots.txt, /sitemap.xml and /no-such-page-qa. Expect a text file, an XML file and a 404. View source on /product for og: and canonical tags and a page-specific title.

Issue	Retest steps and expected result
14	On /product use the language switch in the header and choose Arabic. Expect Arabic text and right-to-left layout on /product, /privacy and /terms.
15	New encounter > Age 250 > Tab: expect an inline error. Click Save draft: expect a confirmation, then leave and reopen to see the draft restored.
16	Assistant: the Issue 16 message (BP 150/95, HR 102, RR 22, SpO2 94%, temp 36.9, creatinine 1.4, sodium 137, potassium 4.3). Expect every value captured, and any unmapped text listed under "Not captured".
18	As a physician open /nurse/roster: expect a redirect. Check the public footer has no Design system link, and /security has no "Sixteen roles".
21	Share & consent > Give someone access > Who: not-an-email. Expect an error and no grant.
22	My records > Structured file. Expect submissions, requests and access history in the file.
23	As a self-serve patient, ask for a correction. Expect a message that it went to ESAP support, not the care team.
24	Share & consent > Who actually looked. Today's events show as minutes or hours ago, not "in 47 d".
25	In Arabic, check the Connect box, access-history labels and symptom chips. As a patient, GET /api/v1/admin/interop: expect 403.
26	Signed out, open the footer: no Design system link. Go to /design: expect the sign-in page.

Remaining before the pilot

- **API domain:** move the API to api.care.esap.ai (Issue 10). Until then Safari and some Firefox settings block the cross-site sign-in cookie, so people get signed out when they reload.
- **Saudi hosting:** choose a CST-licensed Saudi host. The Privacy page says ESAP is not hosted there yet.
- **Mail server:** set ESAP_SMTP_* on production so password reset emails are delivered (Issue 17).
- **Shared demo password:** 14 accounts, including admin and Super-Admin, use it, and two-factor is gone (Issue 1).
- **Legal review:** counsel should review the Privacy and Terms drafts, and the DPO's name should be published before real patient data is used.
- **Hospital list:** it offers only fictional demo hospitals until real hospitals are onboarded.
- **FHIR export:** the export is ESAP's own JSON. FHIR is not built yet.
- **Arabic review:** a native speaker should review the new Arabic public and legal text, including the new Saudi approvals section.
- **Saudi approvals:** none is held yet. The planned list is in Terms; update it as each registration is obtained.